

Sécurisation et supervision du système d'information dans le secteur industriel du test et de la mesure

Mesulog - Moirans

images/Logo_mesulog.jpg

Présenté par

Kenzo Sechi

Jury

IUT : M. Bonnaud

IUT : Mme Laget-Kamel

Société : Mesulog - Nerys Group

Déclaration de respect des droits d'auteurs

Par la présente, je déclare être le seul auteur de ce rapport et assure qu'aucune autre ressource que celles indiquées n'ont été utilisées pour la réalisation de ce travail. Tout emprunt (citation ou référence) littéral ou non à des documents publiés ou inédits est référencé comme tel et tout usage à un outil doté d'IA a été mentionné et sera de ma responsabilité.

Je suis informé qu'en cas de flagrant délit de fraude, les sanctions prévues dans le règlement des études en cas de fraude aux examens par application du décret 92-657 du 13 juillet 1992 peuvent s'appliquer. Elles seront décidées par la commission disciplinaire de l'UGA.

À Moirans

Le 02/06/2026

images/signature.png

Signature

Remerciements

Premièrement, je tiens à préciser que cette année d'alternance au sein de Mesulog fût une grande opportunité m'offrant une seconde expérience au sein du monde professionnel. Je considère avoir beaucoup appris sur les environnements professionnel, la sécurité, le réseau ainsi que l'administration système grâce aux différents collaborateurs qui ont su m'accompagner en m'aidant lorsque j'avais un problème, en me conseillant des solutions cohérentes ou bien en m'expliquant certains concepts clés.

Je souhaite particulièrement remercier :

- **Luc Desruelle (RSSI - Mesulog)** mon tuteur d'alternance qui m'a aidé à contextualiser les projets sur lesquels je travaillais
- **Benjamin Lerch** mon deuxième tuteur, référent de la partie technique, il m'a notamment aidé à mieux connaître l'architecture du système d'information (SI) de l'entreprise.
- **Florent Fonteix (RSSI - Nerys)** avec qui j'ai pu travailler sur la mise en place d'un accès réseau client fortement isolé pour Nerys.
- **Sara Laget-Kamel** qui m'a aidé à rendre un rapport de stage plus clair et compréhensible et qui s'est montré disponible en cas de besoin.
- **Laurent Bonnaud** qui a pris le temps de lire ce rapport afin de m'évaluer
- **L'équipe technique de Mesulog & Nerys** pour leur disponibilité, leur pédagogie, leur aide et leurs conseils précieux.
- **L'équipe Mesulog dans son ensemble** pour l'accueil chaleureux, les échanges constructifs et l'esprit collaboratif qui m'ont permis de progresser tout au long de l'alternance.
- **L'équipe enseignante de l'IUT2** pour les connaissances et bonnes pratiques transmises, qui m'ont été très utiles dans le cadre de cette alternance.

Je souhaite que mon travail contribue à améliorer la sécurisation et la supervision du système d'information de Mesulog. Cette expérience a été très enrichissante et m'a permis de développer mes compétences en administration système, cybersécurité et développement, tout en découvrant le fonctionnement concret d'une entreprise orientée vers l'industrie, un secteur d'activité qui m'était jusqu'ici inconnu.

Table des matières

Table des figures

Introduction

Dans le cadre de ma troisième année de Bachelor Universitaire Technologique en informatique à l'IUT2 de Grenoble, j'ai eu l'opportunité d'effectuer une année d'alternance au sein de Mesulog, une société spécialisée dans le développement de logiciels de test et de mesures pour les environnements industriels. Cette expérience professionnelle m'a permis d'appliquer les connaissances acquises durant ma formation tout en développant de nouvelles compétences techniques et organisationnelles.

Cette alternance s'inscrit dans le cadre de la sécurisation du système d'information de l'entreprise, un enjeu majeur afin de garantir la confidentialité, l'intégrité et la disponibilité des données et des services, conformément au triptyque CIA (Confidentialité, Intégrité, Disponibilité) [**cia-triad**], modèle fondamental qui constitue la base de toute démarche de gestion de la sécurité de l'information, notamment formalisé dans la norme ISO/IEC 27001.

Ce rapport s'organise en quatre parties. La première présente le cadre institutionnel et organisationnel de l'entreprise d'accueil ainsi que le contexte de l'alternance. La seconde détaille les missions techniques réalisées au cours de l'année, en particulier la mise en place d'une supervision de sécurité avec Wazuh et le durcissement du système d'information selon les standards CIS. La troisième partie aborde l'impact environnemental et sociétal des missions menées. Enfin, un bilan personnel revient sur les compétences développées et leur articulation avec le référentiel de formation.

1 Présentation de l'entreprise

1.1 Présentation générale

Mesulog et Nerys constituaient initialement deux entreprises distinctes, ayant respectivement pour domaine d'activités le développement de logiciels de test et de mesures pour l'une et pour l'autre, la conception de **bancs de test**, **baies et coffrets électriques** pour les environnements industriels. Leur rapprochement a conduit à la structuration de **Nerys Group**, société mère intégrant Nerys et Mesulog.

Cette fusion permet ainsi le regroupement des expertises techniques dans les domaines du test, de la mesure et de l'ingénierie logicielle associée aux bancs d'essais. Ce processus de fusion intègre également la société Territoire de Changements devenue ensuite Nerys Group Service permettant ainsi au groupe la proposition de formations techniques (principalement LabVIEW & TestStand).

Nerys Group évolue également dans le milieu de la recherche et du Développement, notamment depuis sa reconnaissance en tant qu'organisme de recherche privé par le Ministère de l'Enseignement Supérieur et de la Recherche.

1.2 Valeurs et orientations stratégiques

La culture d'entreprise de Nerys Group repose sur des valeurs partagées par l'ensemble des collaborateurs. Le **respect de l'humain**, **l'expertise technique** et **le sens du service** constituent les fondements de son fonctionnement. Ces valeurs se traduisent notamment par un fort esprit d'équipe, une logique de confiance et de transparence, ainsi qu'une volonté de partage des compétences.



FIGURE 1 – Pr  sentation des soci  t  s filles de Nerys Group et de leurs directions

L'entreprise met en   uvre une organisation agile et accorde une attention particuli  re    la fi-d  lisation de ses clients. Elle s'appuie   galement sur une politique structur  e en mati  re de qualit   et de cybers  curit  , appliqu  e aussi bien en interne que dans les projets r  alis  s pour ses clients. Par ailleurs, la participation de certains salari  s au capital de l'entreprise contribue    renforcer leur implication dans la performance et la p  rennit   du groupe

1.3 Hi  rarchie de l'  quipe Mesulog

L  gende : Direction Chefs de projet D  veloppeurs/Stagiaires
 Alternant (moi-m  me)

L'organigramme pr  sent   ci-dessus permet de visualiser la structuration actuelle de Mesulog et de comprendre la r  partition des r  les au sein de l'  quipe, ainsi que les liens hi  rarchiques entre la direction, les chefs de projet et les   quipes de d  veloppement. Cette organisation r  sulte d'une   volution progressive d  taill  e ci-apr  s, au fil de la croissance de l'activit  . L'entreprise est fond  e en mars 2000 par Jean-Louis Schricke, qui en assure initialement la direction ainsi que les activit  s de d  veloppement.

En mai 2002, Luc Desruelle rejoint la soci  t   en tant qu'ing  nieur d  veloppement logiciel; en 2026, il occupe d  sormais le poste de directeur de Mesulog et de pr  sident de Nerys Group Service, tout en gardant une place importante dans l'encadrement technique des projets.

La mont  e en charge de l'activit   s'accompagne ensuite d'un renforcement progressif de l'  quipe, avec l'arriv  e de Damien Lamy en 2012, puis d'Anthony Asaro et de Benjamin Lerch en 2019.

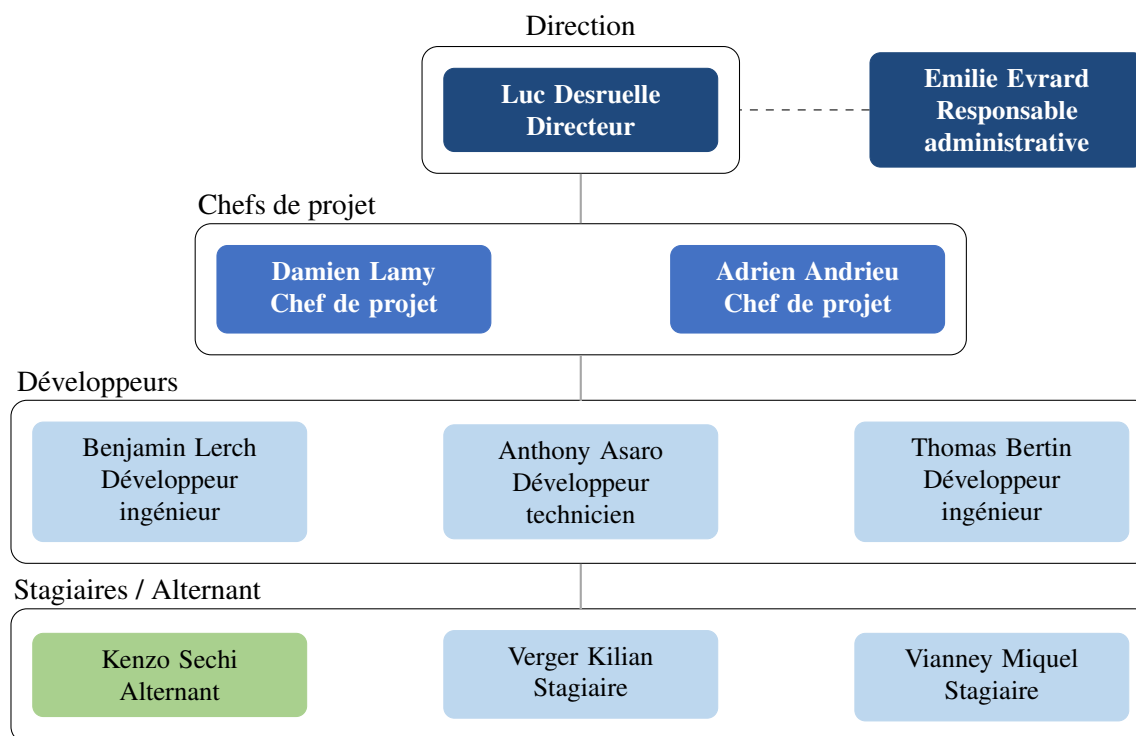


FIGURE 2 – Présentation de la hiérarchie de l'équipe Mesulog

En juillet 2020, l'entreprise évolue en [Société par actions simplifiée](#) (SAS) et intègre Ne-rys Group. Cette étape marque un ajustement de la gouvernance, avec une direction rattachée au groupe, tout en conservant un pilotage opérationnel de proximité sur les activités techniques. Plus récemment, Adrien Andrieu (2023) rejoint l'équipe en tant qu'ingénieur développement. Ainsi, la hiérarchie de Mesulog s'articule autour d'une direction clairement identifiée, d'un encadrement technique historique et d'une équipe projet resserrée, orientée développement, maintien des solutions existantes et accompagnement des besoins clients.

2 Présentation du service d'accueil

J'ai intégré l'équipe technique de Mesulog, composée d'administrateurs systèmes, de développeurs et de deux responsables de la sécurité des systèmes d'information (**RSSI**). Ce service est en charge du maintien en condition opérationnelle du système d'information, de la cybersécurité, du support utilisateur ainsi que du développement et de la maintenance d'outils internes. L'alternance s'inscrit dans un contexte de renforcement global de la sécurité du système d'information et de modernisation de l'infrastructure. L'évolution des exigences clients, la manipulation de données sensibles et l'obsolescence progressive de certaines composantes techniques ont conduit l'entreprise à structurer et renforcer ses pratiques en matière de cybersécurité et de gouvernance du SI.

Dans ce cadre, les missions qui m'ont été confiées répondent à plusieurs enjeux transverses : assurer la conformité aux exigences réglementaires et normatives, améliorer la résilience du système d'information, renforcer la confiance des clients et accompagner la modernisation de l'infrastructure technique. Mon positionnement en tant qu'alternant m'a permis d'intervenir à la fois sur des aspects opérationnels et structurants, en lien étroit avec les équipes techniques et les responsables de la sécurité du système d'information. Les missions présentées dans la suite du rapport illustrent cette double dimension, mêlant actions concrètes de sécurisation et participation à des

démarches d'amélioration continue.

2.1 Environnement technique

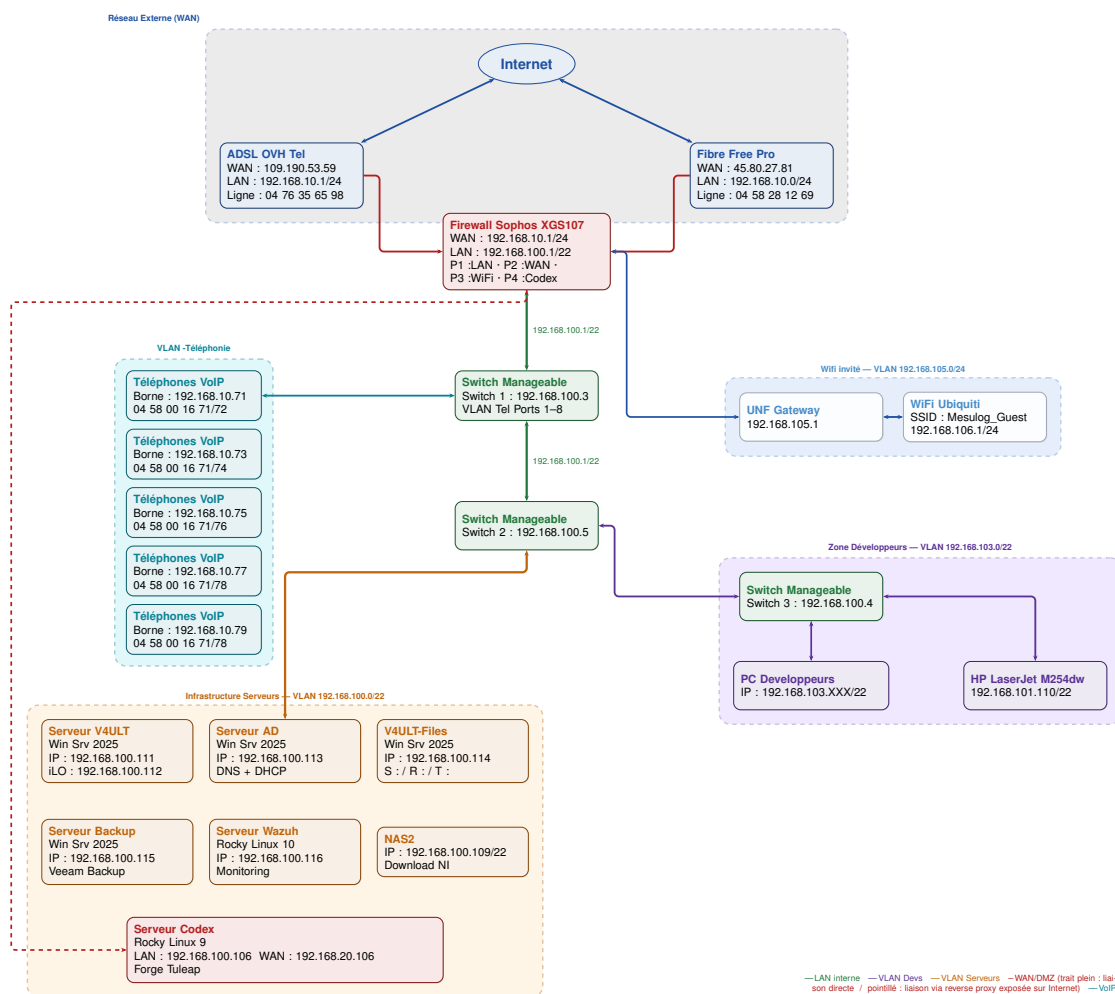


FIGURE 3 – Plan réseau de Mesulog en 2026

Comme on peut le voir sur la figure ??, l'architecture réseau de Mesulog est composé d'une partie serveurs (Windows Server 2025 ou [Rocky Linux 10](#)) hébergeants les services principaux de l'entreprise.

Les serveurs de l'infrastructure sont regroupés sous le nom de domaine interne **V4ULT**, convention de nommage propre à Mesulog désignant l'ensemble du socle serveur de l'entreprise. On y retrouve notamment :

- **V4ULT-AD** : l'Active Directory (Serveur [LDAP](#)) faisant aussi office de Serveur DHCP et DNS.
- **V4ULT-FILES** : Le serveur de fichiers de l'entreprise découpés en 3 entités (Echanges, Mesulog, Downloads)
- **Server Backup** : Le serveur de sauvegarde de l'entreprise utilisant Veeam Backup & Replication.

- **Server Codex** : Instance de Tuleap, similaire à GitLab, gestionnaire de version de code source basé SVN. Le serveur est exposé sur internet derrière un reverse proxy et un firewall.

Quant à l'environnement logiciel, les utilisateurs, principalement des développeurs LabVIEW & TestStand, utilisent Windows 11 avec la suite de logiciels suivante :

- **Oracle VirtualBox** : virtualisation pour exécuter des machines virtuelles locales.
- **Suite Microsoft 365** : bureautique et collaboration (Outlook, Word, Excel, Teams...).
- **Firefox** : navigateur web principal pour la navigation et les outils web internes.
- **TeamViewer** : assistance à distance et support technique.

Les logiciels utilisés dans les machines virtuelles peuvent être les suivants :

- **LabVIEW** : environnement de développement pour les applications de test et mesure.
- **TestStand** : Séquenceur de tests automatisés.
- **Logiciels propriétaires clients** : applications spécifiques fournies par des clients (e.g. ?)

2.2 Organisation des missions

Le diagramme ci dessous présente la chronologie des différentes missions effectuées durant cette année d'alternance, bien que certaines missions comme *l'homologation du Système d'Informations (SI) classé "DR"* ou bien la *migration de l'Active Directory (AD)* étaient prévus pour une date donnée ou une date butoire, les autres ne bénéficiaient d'aucun ordre établi à l'avance :

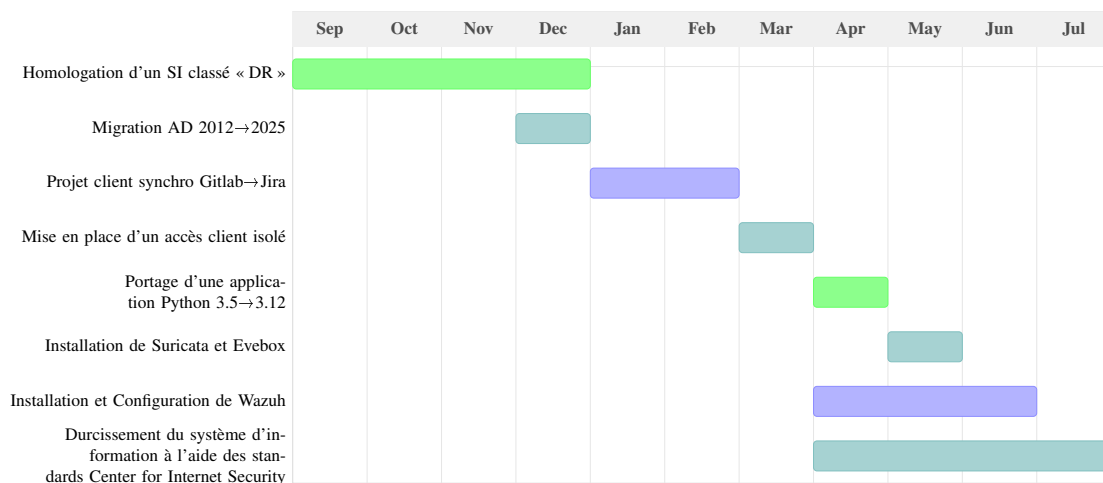


FIGURE 4 – Chronologie des missions réalisées pendant l'alternance

3 Missions effectuées

Après avoir posé le cadre institutionnel et professionnel de l’alternance, il est désormais pertinent de présenter en détail le sujet traité, les objectifs poursuivis ainsi que le déroulement chronologique des missions réalisées. Ces éléments permettent de saisir la portée technique de l’alternance et la logique d’ensemble des projets menés.

3.1 Mission 1 : Installation et Configuration de Wazuh

Dans un système d’information (SI), il est primordial de surveiller les comportements utilisateurs et systèmes afin de prévenir certaines pannes, accidents, comportements inappropriés et attaques. La surveillance via divers outils comme les EDR, IDS/IPS et les Security Information and Event Management (SIEM) s’inscrit ainsi dans une démarche de sécurité et de sûreté vis-à-vis du SI, de ses utilisateurs ainsi que des différents actifs de l’entreprise qu’il est important de protéger. De plus, un SIEM peut également servir en tant que plateforme de journalisation, notamment dans un but de conformité aux standards ISO27001 (ex : A.8.15).

Cette supervision continue se justifie par le fait qu’un contrôle ponctuel ou a posteriori arrive souvent trop tard pour limiter l’impact d’un incident : l’analyse en quasi temps réel de journaux systèmes, applicatifs ou réseau (par exemple sous forme de captures PCAP pour le trafic réseau) permet à l’inverse de détecter rapidement des comportements anormaux ou malveillants. Elle complète également la réalisation d’audits réguliers, qui permettent de vérifier que les mesures de sécurité mises en place restent conformes aux exigences réglementaires et aux bonnes pratiques, et de détecter les écarts de configuration avant qu’ils ne soient exploités par un attaquant.

Cette surveillance se base ici sur Wazuh, un SIEM servant de point de centralisation des journaux des machines du parc. Ce choix, parmi les solutions disponibles sur le marché (Splunk, Elastic Security, IBM QRadar, etc.), s’explique principalement par son caractère open source, l’absence de coût de licence adapté au contexte budgétaire de l’entreprise, ainsi que la richesse de son moteur de règles natif et de son module de conformité (SCA) directement compatible avec les benchmarks CIS, déjà retenus par l’entreprise pour le durcissement du parc (cf. section ??).

3.1.1 Qu’est-ce que Wazuh

Wazuh est un SIEM, une plateforme permettant de centraliser, analyser enrichir et corréler les événements de sécurité afin de détecter des menaces. Il permet de surveiller une gamme d’équipements via le protocole Syslog ainsi que l’aide de ses agents. Les agents sont des logiciels installés sur les appareils administrés qui ont pour principal fonction de remonter les journaux systèmes ou applications des machines, ils peuvent également exécuter des commandes avec un privilège administrateur sur les machines ce qui peut s’avérer utile pour un outil de scan de permission par exemple mais dangereux dans le cas où une personne mal intentionnés arrive à prendre la main sur le serveur qui les déploie.

3.1.2 Les protocoles de Transmission de journaux

Le protocole Syslog est un protocole permettant l’échange de journaux système entre un serveur et un client dans un format centralisé défini selon les standards de la RFC 5424. Chaque champ est défini par cette norme et les valeurs stockées dedans également, à l’exception de certains champs laissés libre afin de permettre aux développeurs d’enrichir les logs de leur programme.

Le protocole est disponible en deux versions, TCP qui assure la transmission fiable des informations (port 5514) et UDP (port 514) permettant un trafic plus important mais moins fiable.

Exemple de structure d'un message au format Syslog, conforme à la RFC 5424 :

Sep 14 14:09:09	machine_de_test	dhcp service	warning	110	corps du message
Date et heure	Hostname	Processus	Priorité	PID	Message

TABLE 1 – Structure d'un message Syslog

Outre Syslog, d'autres formats de journaux sont également utilisés dans les systèmes d'information. Parmi eux, le format Common Event Format (CEF)¹, développé par ArcSight, permet de standardiser les événements de sécurité provenant d'équipements et de logiciels différents.

1. <https://www.microfocus.com/documentation/arcsight/>

3.1.3 Architecture de Wazuh

Avant de détailler la mise en œuvre réalisée durant l’alternance, il convient de présenter l’architecture générale de Wazuh, qui repose sur une organisation modulaire en plusieurs composants communiquant entre eux.

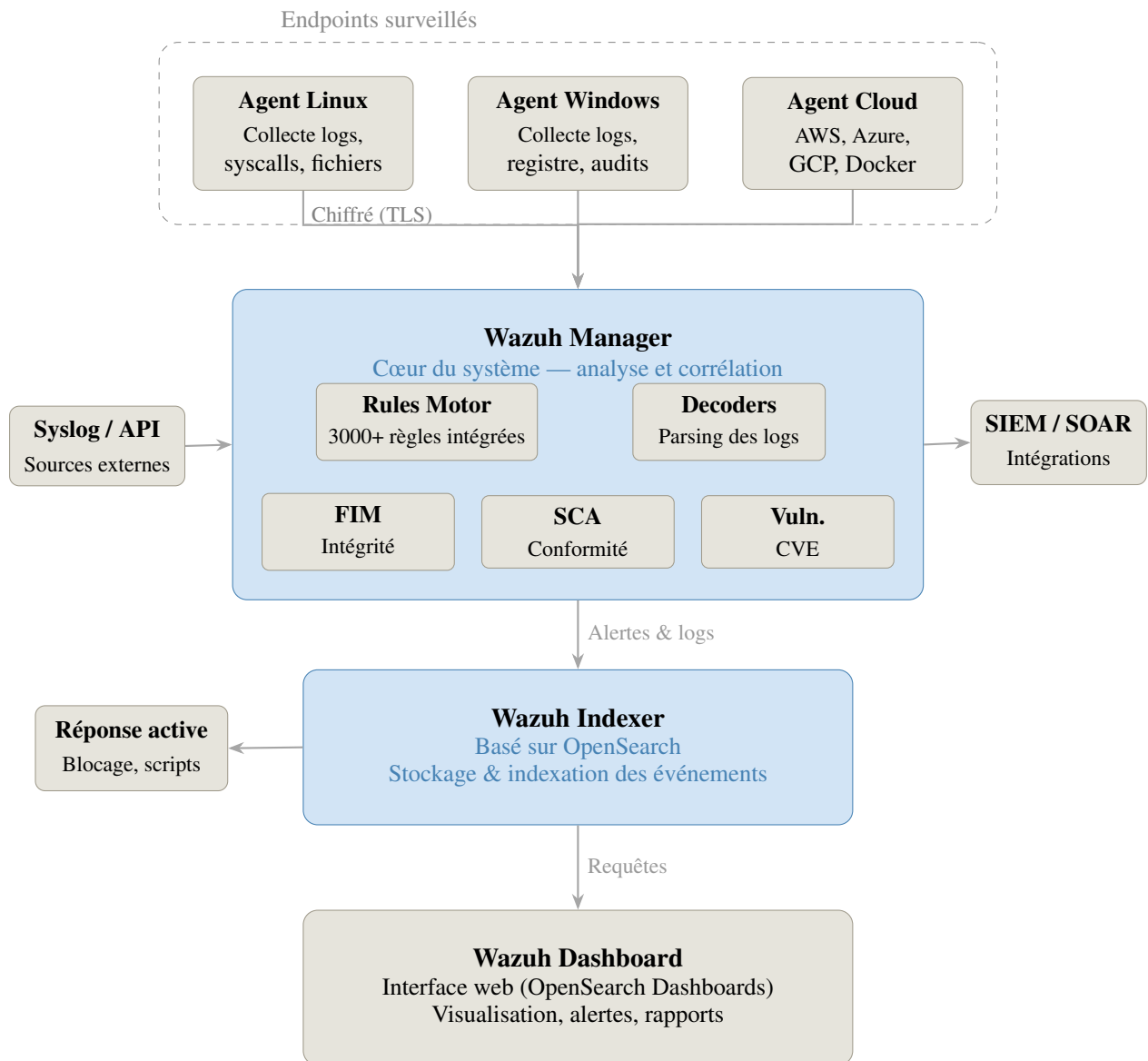


FIGURE 5 – Architecture fonctionnelle de Wazuh

Comme on peut le voir sur la figure ??, Wazuh se compose de quatres éléments principaux :

- les agents, qui collectent les données de sécurité à partir des systèmes surveillés et les transmettent au Manager via le protocole Syslog TCP ou d’autres méthodes de communication.
- le Manager, qui est le cœur du système, chargé de collecter, analyser et corréler les journaux envoyés par les agents.
- l’Indexer, basé sur OpenSearch, qui stocke et indexe les données pour permettre des recherches rapides et efficaces.

- le Dashboard, qui offre une interface web pour visualiser les alertes, générer des rapports, interagir avec les données collectées et configurer l'outil.

Le schéma fait également apparaître des intégrations possibles vers des solutions SIEM/SOAR tierces. Un Security Orchestration, Automation and Response (SOAR) est une plateforme qui automatise les réponses à des alertes de sécurité (par exemple le blocage automatique d'une adresse IP suspecte), en s'appuyant généralement sur les événements remontés par un SIEM comme Wazuh.

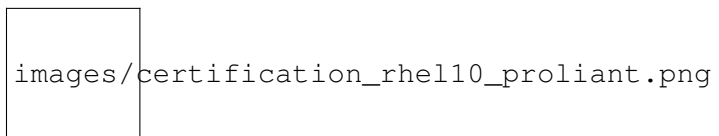
Le Manager intègre également des modules complémentaires, dont le File Integrity Monitoring (FIM), qui surveille les modifications de fichiers et de clés de registre sensibles, le module de conformité SCA (Security Configuration Assessment) qui sera détaillé en section ??, ainsi qu'un module de détection de vulnérabilités basé sur les CVE connues.

3.1.4 Mise en place de Wazuh

3.1.4.1 Que faut-il mettre en place ?

La mise en place de Wazuh a été réalisée sur un serveur Rocky Linux 10 (RHEL 10) virtualisé via l'hyperviseur Hyper-V, sur un serveur physique [HPE ProLiant DL360 Gen10 Plus](#).

Le choix de ce système d'exploitation s'explique par sa stabilité ainsi que l'assurance de son support à long terme (10 ans) ce qui est un critère important pour une entreprise, de plus, RedHat assure une compatibilité totale matérielle avec les serveurs HPE via le grade "Certified" consultable sur le site web de l'entreprise ce qui n'est pas forcément proposé par d'autres Systèmes d'exploitation.



Le processus d'installation de Wazuh s'est déroulé en trois étapes principales :

- La création d'une VM HyperV ayant les paramètres adaptés (stockage, cpu, ram etc.)
- L'installation des différents composants (Wazuh Manager, Wazuh Indexer et Wazuh Dashboard) sur la VM
- L'ajout d'un enregistrements DNS afin de rendre la configuration plus maintenable

Je n'ai pas eu besoin de réinstaller les agents sur les ordinateurs mais seulement de modifier l'adresse de wazuh vers son nom **ex : 192.168.1.12 → wazuh.mesulog.local**

Le processus d'installation est disponible dans les figures ?? et ?? disponibles en annexe.

3.1.5 Les décodeurs règles et alertes

Une fois Wazuh installé et les agents configurés, l'enjeu principal devient l'exploitation effective des journaux collectés : il faut être capable d'en extraire les informations pertinentes, de les comparer à des critères de détection, puis de générer des alertes exploitables par les équipes de sécurité. C'est le rôle conjoint des décodeurs, qui interprètent la structure des logs, des règles, qui définissent les critères de détection, et des alertes, qui formalisent la remontée d'information. Cette sous-section détaille le fonctionnement de cette chaîne ainsi que les éléments personnalisés mis en place durant l'alternance.

3.1.5.1 Fonctionnement général

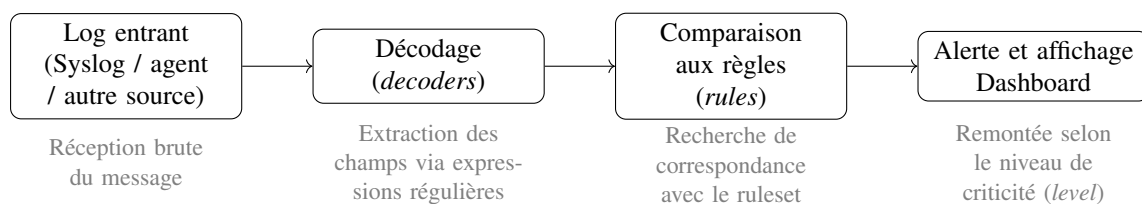


FIGURE 6 – Chaîne de traitement d'un log dans Wazuh

Ce schéma présente le processus de gestion de l'arrivée d'un log dans Wazuh Manager jusqu'à la montée d'alerte traitée par un administrateur système ou un analyste SOC. Ce traitement s'appuie sur un mécanisme de *pattern matching* : à chaque étape, le contenu du log est comparé à un ensemble de motifs prédéfinis (expressions régulières pour les décodeurs, critères de correspondance pour les règles) afin d'en extraire des informations exploitables puis de déclencher, le cas échéant, une alerte. Le fonctionnement détaillé des décodeurs et des règles est présenté dans les paragraphes suivants.

- D'abord le log arrive sur un des ports ouverts de Wazuh Manager (514 Syslog UDP, 1515 agent, etc.)
- Le log est ensuite parsé par un décodeur, cette étape peut se répéter plusieurs fois si le résultat obtenu en sortie correspond à un autre décodeur.
- Le résultat est ensuite comparé aux différentes règles incluses dans Wazuh ainsi qu'aux règles personnalisées ; si une correspondance est avérée, une règle est levée et apparaît dans le Dashboard Wazuh (si son niveau est supérieur à 0).
- Il est alors possible de créer des alertes en fonction du niveau de chaque règle levée ; ces alertes peuvent être envoyées via différents canaux (mail, Teams, Slack).

3.1.5.2 Décodage de journaux, fonctionnement des "decoders"

Les décodeurs représentent la première couche de traitement de logs dans wazuh, il en existe 2 sortes :

- les natifs, présents sous `/var/ossec/ruleset/decoder/0XXX-Nom`
- les customs, présents sous `/var/ossec/etc/decoder/Nom`

Les décodeurs custom ont plusieurs fonctions, ils permettent notamment d'interpréter des logs provenant de sources pour lesquelles wazuh ne propose pas de décodeur intégré, ou de surcharger certains décodeurs existant afin d'enrichir le log. Voici un exemple de décodeur :

```
1 <decoder name="ms-dhcp-ipv4">
2   <prematch>^\d\d,\d+/\d+/\d\d\d\d,\d+:\d+:\d+,|</prematch>
3   <prematch>^\d\d,\d+/\d+/\d\d,\d+:\d+:\d+,</prematch>
4   <regex>^(\d\d),\d+/\d+/\d\d\d\d*,\d+:\d+:\d+,(w+),(S+)</regex>
5   <order>id,extra_data,srcip</order>
6 </decoder>
```

FIGURE 7 – Exemple décodeur DHCP

Ce décodeur permet d'analyser les journaux générés par le service DHCP de Windows. Il repose sur un *pattern matching*, c'est-à-dire une comparaison entre le texte du log et un modèle attendu : si le message suit la même structure que celle décrite dans le décodeur, il est reconnu. Par exemple, une ligne commençant par `24,05/08/2024,12:41:18,DNS Update Request,201.10.168.192` correspond au modèle attendu car elle respecte l'ordre des champs définis.

Les expressions régulières, ou *regex*, sont le langage utilisé pour décrire ce modèle. Concrètement, elles servent à repérer des motifs dans une chaîne de caractères : `\d` désigne un chiffre, `w` un mot, et `S+` une suite de caractères sans espace.

Dans l'exemple ci-dessus, la *regex* permet d'isoler automatiquement l'identifiant de l'événement, les données complémentaires et l'adresse IP source, qui pourront ensuite être exploitées par les règles de détection de Wazuh. Les champs extraits sont ensuite stockés dans des variables Wazuh (`id`, `extra_data`, `srcip`). Voici les champs extraits par ce décodeur :

24	DNS Update Request	201.10.168.192
id	extra_data	srcip

TABLE 2 – Champs extraits par le décodeur DHCP

Après application du décodeur, ces variables sont utilisées pour la création de règles personnalisées ou pour l'affichage d'alertes plus détaillées dans le dashboard Wazuh.

3.1.5.3 Les règles "Rules"

Les règles sont déclenchés en fonction des logs décodés lorsqu'un log correspond à leurs critères, leurs champ *level* permettent d'attribuer une criticité de 0 à 15, le détail sur la criticité est expliqué dans le tableau suivant qui apparaît sur la page d'accueil Wazuh.



images/criticité-règles.png

FIGURE 8 – Criticité des règles Wazuh

3.1.6 Création de règles personnalisées

Les règles personnalisées permettent de créer des alertes spécifiques en fonction des besoins de l'entreprise. Elles suivent globalement le même fonctionnement que les décodeurs, elles sont composées d'une partie de pré-matching qui permet de filtrer les logs à traiter, d'une partie de matching qui permet d'extraire des champs du log et d'une partie de description qui permet de définir le message d'alerte qui sera affiché dans le dashboard Wazuh.

Il est possible pour une règle de faire référence à une autre règle via la balise `if_sid`, ce qui permet de faire du chaînage de règles (chaining), c'est à dire que si une règle est levée, elle peut faire référence à une autre règle qui elle même peut faire référence à une autre règle etc.

3.1.6.1 Travail réalisé

Plusieurs règles personnalisées ont été créées, l'objectif principale était de détecter la présence de nouveaux appareils sur le réseau LAN ou sur le réseau wifi (invité) de l'entreprise.

Pour ce faire, j'ai créé deux règles permettant de vérifier les baux DHCP renouvelés sur le réseau wifi invité de l'entreprise ainsi que 2 règles permettant de vérifier les baux DHCP renouvelés sur le réseau LAN de l'entreprise. L'objectif était de détecter les appareils connus et inconnus se connectant au réseau, en utilisant une liste blanche d'adresses MAC autorisées définie sur le serveur Wazuh. Voici les exemple de règles personnalisées créées pour cette surveillance :

```
1 <group name="dhcp">
2   <rule id="120052" level="3">
3     <if_sid>6305</if_sid>
4     <list field="mac" lookup="match_key">etc/lists/known-devices</list>
5     <description>DHCP lease renewed for $(mac) = $(srcip)</description>
6   </rule>
7   <rule id="120053" level="12">
8     <if_sid>6305</if_sid>
9     <list field="mac" lookup="not_match_key">etc/lists/known-devices</list>
10    <description>ALERT! Unknown device connected: for $(mac) = $(srcip)
11    </description>
12  </rule>
13 </group>
```

FIGURE 9 – Exemple de règles personnalisées pour vérifier la whitelist DHCP

Ci-dessus, deux règles personnalisées ont été créées pour vérifier les baux DHCP renouvelés sur le wifi invité de la société. La première règle (ID 120052) est déclenchée lorsque le champ "mac" du log correspond à une adresse MAC présente dans la liste "known-devices", indiquant qu'un appareil connu a renouvelé son bail DHCP. La seconde règle (ID 120053) est déclenchée lorsque le champ "mac" ne correspond pas à une adresse MAC de la liste, signalant la connexion d'un appareil inconnu et générant une alerte critique.

La mise en place de ces règles a également mis en évidence une difficulté importante : contrairement à des langages de requête comme le KQL (plus lisible et orienté analyse), la logique de corrélation dans Wazuh repose sur une structure XML plus verbeuse et moins intuitive. En pratique, cela rend l'écriture, la relecture et la maintenance des règles plus longues, en particulier pour des tâches d'administration système où l'on doit itérer rapidement, tester souvent et limiter les erreurs de syntaxe.

3.1.6.2 Alertes

Les alertes constituent une fonction centrale du SIEM, permettre d'alerter les équipes de sécurité en cas d'événements suspects ou critiques détectés. Elles peuvent être configurées pour être envoyées via différents canaux de communication, tels que les emails, les notifications sur des plateformes de collaboration ([Teams](#), [Slack](#)) ou même des intégrations avec des systèmes de ticketing comme [GLPI](#) ou [Jira](#), permettant ainsi de créer un ticket d'incident automatiquement afin qu'un technicien de support puisse intervenir au plus vite, cela peut-être intéressant dans une grande structure avec un SI complexe.

Contexte et travail réalisé Dans un premier temps, la DSI souhaite assurer un contrôle efficace des accès et des activités sur le réseau, en particulier pour détecter les tentatives de connexion échouées et la présence d'appareils inconnus sur le réseau LAN et wifi.

Une attention particulière fut également portée à la surveillance des activités sur le serveur SharePoint, afin de détecter toute suppression massive de fichiers ou dossiers, ce qui pourrait indiquer une activité malveillante ou non autorisée (e.g. tentative de suppression de masse).

Voici les alertes qui ont été mises en place afin de répondre à ces besoins :

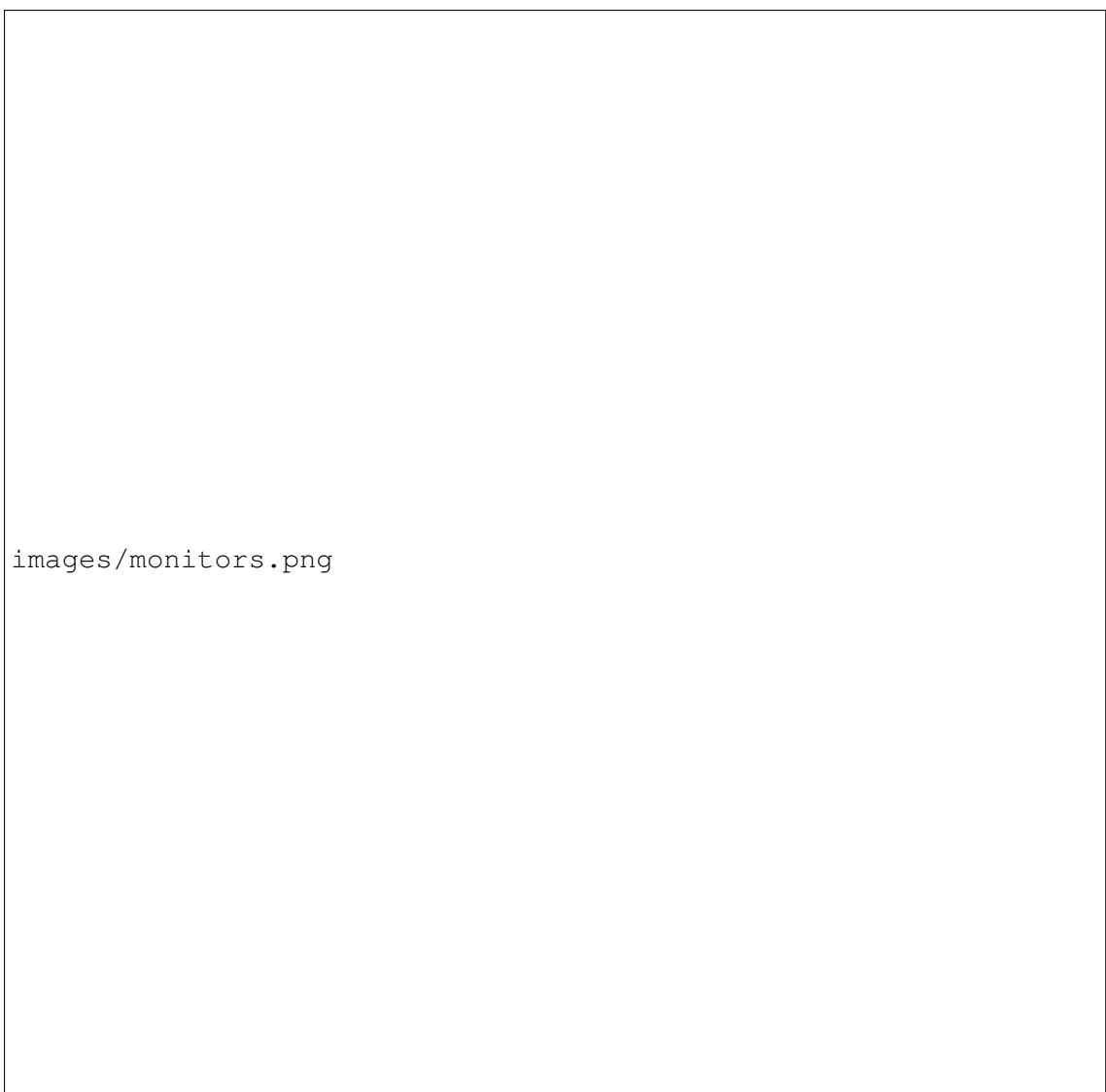
- **Windows Multiple Logon Failure** : Cette alerte est déclenchée lorsqu'il y a plusieurs tentatives de connexion échouées sur une session utilisateur d'un système Windows (événement [4625](#)), cela peut indiquer une attaque bruteforce ou une tentative d'accès non autorisée.
- **Sharepoint Remove detection** : Cette alerte est générée lorsqu'une suppression d'au moins 5 fichiers ou dossiers est détectée sur notre serveur SharePoint dans une intervalle de 1 minutes, ce qui peut signaler une activité suspecte ou malveillante.
- **Appareil non-connu détecté sur le réseau LAN** : Cette alerte est déclenchée lorsqu'un appareil inconnu se connecte au réseau LAN de l'entreprise, en utilisant une adresse MAC qui n'est pas présente dans la liste blanche des appareils autorisés. Elle est corréllé à la règle *120053* créé en amont. Cela permet de détecter rapidement les connexions non autorisées et de prendre des mesures appropriées pour sécuriser le réseau interne.
- **Appareil non-connu détecté sur le réseau wifi** : Cette alerte est déclenchée lorsqu'un appareil inconnu se connecte au réseau wifi invité de l'entreprise, en utilisant une adresse MAC qui n'est pas présente dans la liste blanche des appareils autorisés. Elle est corréllé à la règle *120051* créé aussi en amont. Cela permet de détecter rapidement les connexions non autorisées et de prendre des mesures appropriées pour sécuriser le réseau invité.

Observons maintenant comment est définie une de ces alertes, en détail, voici l'exemple de l'alerte *Appareil non-connu détecté sur le réseau LAN*. Cette alerte a été configurée dans OpenSearch Dashboards pour utiliser un moniteur de type *Per bucket monitor* basé sur une requête d'agrégation utilisant l'index Wazuh contenant les logs DHCP.

3.1.6.3 Architecture de l'alerte

L'alerte fonctionne selon une architecture en 3 niveaux : la **détection** au niveau de la règle Wazuh (rule 120053), l'**agrégation des données** via une requête Elasticsearch, et finalement la **notification** déclenchée par le moniteur OpenSearch.

1. **Détection au niveau Wazuh** : La détection commence au niveau de la règle Wazuh ID 120053 (cf. figure ??), qui s'active lorsqu'un appareil avec une adresse MAC non présente dans la liste blanche *known-devices* se connecte au réseau DHCP. Cette règle déclenche automatiquement un log d'alerte avec un niveau de criticité 12 (critique).



images/monitors.png

FIGURE 10 – Alertes configurées dans Wazuh

2. **Requête d'agrégation et d'indexation** : Le moniteur OpenSearch utilise une requête Elasticsearch sophistiquée pour interroger ces logs et agréger les données par adresse MAC. Voici la composition de cette requête :

```

1  {
2    "size": 0,
3    "query": {
4      "bool": {
5        "filter": [
6          {
7            "range": {
8              "@timestamp": {
9                "from": "{{period_end}}|-1h",
10               "to": "{{period_end}}",
11               "include_lower": true,
12               "include_upper": true,
13               "format": "epoch_millis"
14             }
15           }
16         ],
17         {
18           "term": {
19             "rule.id": {
20               "value": "120053"
21             }
22           }
23         }
24       ],
25       "adjust_pure_negative": true,
26       "boost": 1
27     }
28   },
29   "aggregations": {
30     "by_device": {
31       "composite": {
32         "size": 100,
33         "sources": [
34           {
35             "mac_address": {
36               "terms": {
37                 "field": "data.srcmac"
38               }

```

FIGURE 11 – Requête d'agrégation Elasticsearch pour le moniteur de détection d'appareils inconnus au format JSON

Cette requête effectue les opérations suivantes :

- **Filtrage temporel** : Récupère tous les logs générés au cours de la dernière heure (intervalle d'exécution du moniteur).
- **Filtrage par règle** : Sélectionne uniquement les logs associés à la règle 120053 (appareils non-connus).
- **Agrégation composite** : Regroupe les résultats par adresse MAC source (`data.srcmac`) pour obtenir une liste unique des appareils détectés.

Condition de déclenchement Le moniteur évalue ensuite une condition de déclenchement basée sur le résultat de l'agrégation :

```

1 {
2   "buckets_path": {
3     "_count": "_count"
4   },
5   "parent_bucket_path": "by_device",
6   "script": {
7     "source": "params._count > 0",
8     "lang": "painless"
9   },
10  "gap_policy": "skip"
11 }

```

FIGURE 12 – Condition de déclenchement du moniteur

Le script Painless vérifie que le nombre de documents trouvés (`params._count > 0`) est strictement supérieur à zéro. Si au moins un appareil inconnu est détecté dans la dernière heure, le moniteur bascule à l'état *alert* et déclenche les actions configurées.

Configuration du moniteur Le moniteur OpenSearch est configuré selon les paramètres suivants :

- **Type de moniteur** : Per bucket monitor (un moniteur par agrégation).
- **Fréquence d'exécution** : Toutes les 1 minute(s).
- **Sévérité** : Niveau 2 (High) - reportée en tant que *Critical* par Wazuh.
- **Throttling** : 720 minutes (12 heures) - pour éviter une surcharge de notifications en cas de détections répétées.
- **Actionnable** : Par alerte (une notification par événement détecté).

5. Configuration de la notification par email Lors du déclenchement, le moniteur envoie une notification par email via le canal administrateur. Le modèle de message inclut les variables contextuelles pour fournir des détails techniques :

```

1  Un appareil inconnu a ete detecte sur votre reseau.
2
3  -----
4  DETAILS DE L'ALERTE
5  -----
6  Moniteur      : {{ctx.monitor.name}}
7  Declencheur   : {{ctx.trigger.name}}
8  Severite      : {{ctx.trigger.severity}} / 5
9  Appareil      : {{ctx.alert.bucket_keys}}
10 Debut         : {{ctx.periodStart}} UTC
11 Fin          : {{ctx.periodEnd}} UTC
12 -----
13
14 Actions recommandees :
15 1. Identifier l'adresse MAC dans les logs DHCP
16 2. Localiser l'appareil sur le reseau
17 3. Bloquer l'accès si non reconnu
18
19 Consultez les alertes dans OpenSearch Dashboards pour plus
20 de details.

```

FIGURE 13 – Modèle de message d'alerte email

3.1.6.4 Visualisation dans OpenSearch

La configuration du moniteur est visible dans l'interface OpenSearch Dashboards (cf. figure ??).

Le moniteur affiche :

- La requête d'extraction en JSON (Extraction query editor).
- L'index source : `wazuh-alerts-*` (wazuh-indexer-cluster).
- La condition de déclenchement en Painless.
- L'historique des performances et des triggers exécutés.



FIGURE 14 – Configuration du moniteur dans OpenSearch Dashboards - Vue d'ensemble

Flux complet d'alerte Le flux complet de détection fonctionne selon le schéma suivant :

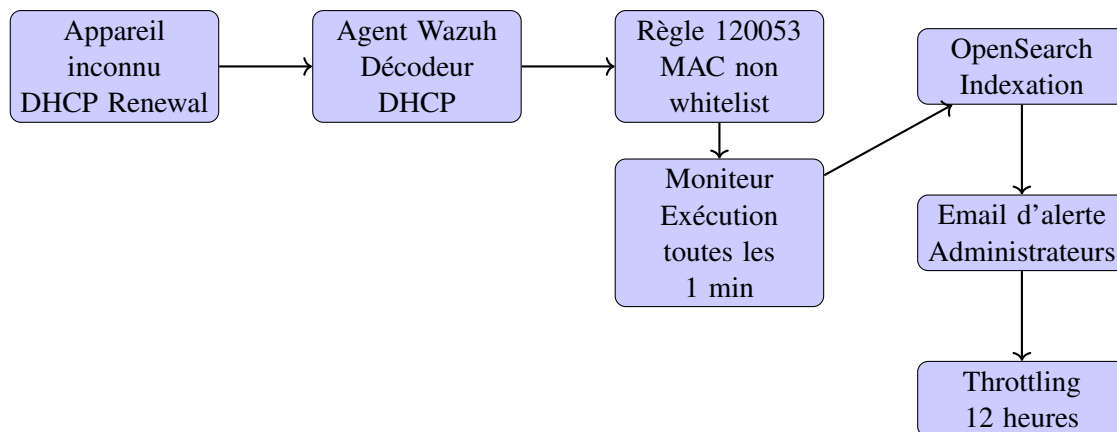


FIGURE 15 – Flux complet de détection des appareils inconnus

Cette architecture garantit une détection rapide (< 2 minutes) des appareils non autorisés tout en maintenant une granularité d'alerte appropriée et en évitant une surcharge d'alertes.

3.1.7 Conclusion de la mission et critiques

Cette mission m'a permis de développer une première expérience avec les SIEM et de comprendre les enjeux liés à la sécurité avec un cas concret. Le but était de sécuriser grâce à une supervision les actifs primordiaux de la société (serveur SharePoint et réseau LAN) par la mise en place d'un SIEM mais également la création de règles ainsi que la remontée d'alertes afin de détecter les comportements anormaux.

J'ai pu mettre en pratique mes connaissances en administration système et les développer en sécurité informatique. Cependant, j'ai également rencontré certaines difficultés dues à un manque d'expérience ainsi qu'à un manque de clarté dans la documentation de la plateforme, notamment sur la partie des décodeurs et des règles pour le fonctionnement de l'héritage, cela m'a obligé à faire beaucoup de recherches sur des forums (cas concrets) afin de comprendre le fonctionnement de Wazuh.

3.2 Mission 2 : Durcissement du système d'information à l'aide des standards CIS

L'une de mes missions principales a été de contribuer au durcissement du système d'information de l'entreprise en appliquant les recommandations du Center for Internet Security (CIS).

3.2.0.1 Durcissement système

Le durcissement système est un ensemble de procédés de restriction des droits visant à réduire la surface d'attaque possible sur un système informatique, cette mission se concentre sur le durcissement d'ordinateurs Windows 11 via les Group Policy Objects (GPO) mais le procédé de durcissement existe également sur les systèmes Linux. Il y a plusieurs façon de durcir des systèmes comme l'installation d'une image préconfiguré pour être durcie ou bien l'application de GPO suivant des standards prédéfinis.

3.2.1 Les standards CIS

Plusieurs standards sont disponibles afin de durcir les systèmes windows, notamment :

- Microsoft Security Baselines
- CIS Benchmarks
- NIST Cybersecurity Framework
- STIGs (Security Technical Implementation Guides)

Le CIS propose des benchmarks de sécurité pour différents systèmes d'exploitation, applications et configurations, visant à réduire les vulnérabilités et à renforcer la résilience face aux attaques. Ces benchmarks sont organisés en 2 niveaux :

- le Level 1 représente les configurations de sécurité essentielles et facilement déployables
- le Level 2 inclut des mesures plus restrictives adaptées aux environnements hautement sécurisés.

Après évaluation des différents standards disponibles, nous avons décidé d'appliquer les standards CIS Level 1 sur l'ensemble de notre parc informatique. Ce choix a été motivé par le fait que les benchmarks CIS Level 1 sont déjà présents et intégrés dans le module [Security Configuration Assessment \(SCA\)](#) de Wazuh, permettant ainsi une détection et une validation automatisées des configurations de sécurité sans nécessiter des outils supplémentaires.

3.2.1.1 Alignement avec ISO 27001

L'application des recommandations CIS Level 1 s'aligne naturellement avec les exigences de la norme ISO 27001. En effet, les baselines CIS contribuent au traitement des risques et à la mise en œuvre de mesures techniques et organisationnelles correspondant aux contrôles d'Annexe A par exemple la gestion des accès, exploitation sécurisée et protection des actifs (A.9, A.12, A.8). Cette approche facilite la démonstration de conformité lors d'un audit ISO 27001 en fournissant des preuves de configuration, de surveillance et d'amélioration continue des contrôles de sécurité.

3.2.2 Création d'un schéma structuré dans l'Active Directory

Avant de déployer les configurations, la première étape était de créer un schéma structuré dans l'Active Directory (AD) afin de mieux hiérarchiser les comptes utilisateurs ainsi que les ordinateurs et serveurs présents sur le domaine. Cette structuration permet de faciliter la gestion des permissions, d'améliorer la visibilité sur les ressources et de renforcer la sécurité en limitant les accès aux ressources sensibles par le principe du moindre privilège. Ce principe consiste à accorder à chaque utilisateur ou système uniquement les permissions minimales nécessaires pour accomplir ses tâches, réduisant ainsi la surface d'attaque en cas de compromission d'un compte.

Cette approche s'inscrit dans une stratégie plus large de *security by design*, qui vise à intégrer la sécurité dès la conception des systèmes et processus plutôt que de l'ajouter après coup. Le *security by design* repose sur des principes fondamentaux tels que la défense en profondeur, la séparation des responsabilités, et la mise en place de contrôles à plusieurs niveaux pour garantir une protection robuste contre les menaces.

Voici le schéma Active Directory initialement mis en place :

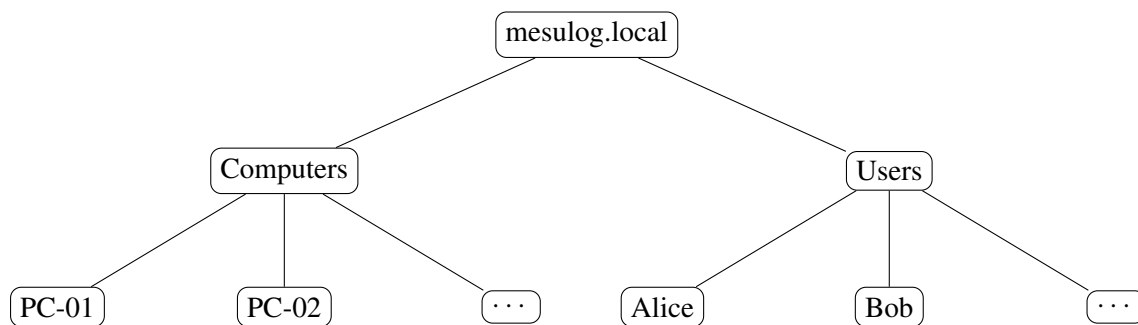


FIGURE 16 – Organisation initiale de l'Active Directory

Bien que ce schéma minimale soit fonctionnel, il ne permet pas de gérer efficacement les ressources et les permissions, il présente les défauts suivants :

- Absence d'Unités d'Organisation (OU) pour regrouper les ressources par fonction, département ou niveau de sensibilité.
- Manque de groupes de sécurité pour attribuer des permissions de manière centralisée et éviter les permissions directes sur les comptes utilisateurs ou ordinateurs.
- Difficulté à appliquer des stratégies de groupe (GPO) spécifiques à certaines catégories d'utilisateurs ou d'ordinateurs en raison de l'absence de hiérarchie claire.

Afin de pallier à ces problèmes, il a été proposé et mis en place une nouvelle organisation de l'Active Directory, structurée autour de plusieurs OU et groupes de sécurité. Cette nouvelle organisation permet une gestion plus efficace des ressources, une meilleure application des politiques de sécurité et une réduction des risques liés à des permissions mal configurées. Voici le schéma de l'Active Directory après restructuration :

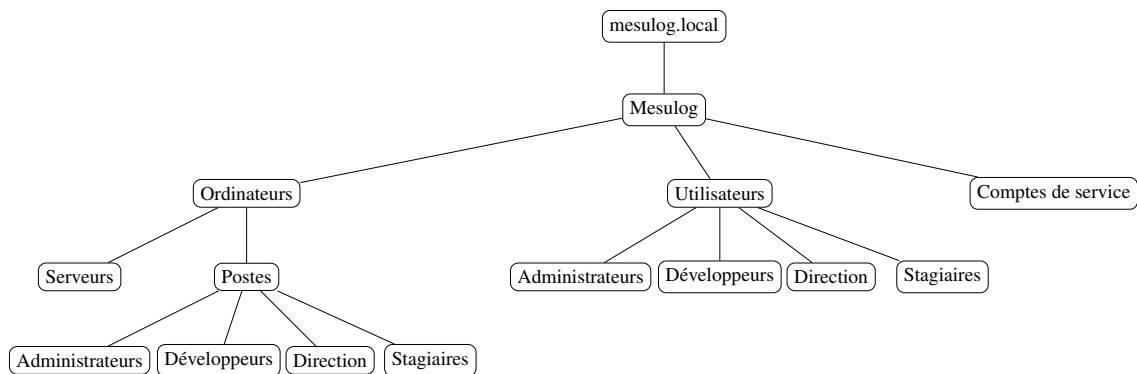


FIGURE 17 – Organisation de l'Active Directory après restructuration

Le schéma ci-dessus représente l'organisation finale de l'Active Directory, son découpage est le suivant :

- **Ordinateurs** composé de l'OU **Postes** réparties entre les **Administrateurs**, **Développeurs**, **Direction** et **Stagiaires** ainsi que de l'OU **Serveurs**
- **Utilisateurs** composé des différents utilisateurs du domaine également répartie entre les **Administrateurs**, **Développeurs**, **Direction** et **Stagiaires**
- **Comptes de services** composé des comptes utilisés par certains serveurs pour accéder à différentes machines et serveurs présents sur le domaine, le but est d'éviter d'utiliser un seul compte qui aurait trop de droits sur l'ensemble du domaine en définissant un compte par utilisation (e.g. compte de sauvegarde)

Ce découpage permet de mieux hiérarchiser les droits selon les personnes dans l'entreprise, les développeurs bénéficient par exemple de plusieurs droits relatifs à la virtualisation afin de développer dans des machines virtuelles, les autres fonctions de l'entreprises comme la Direction qui ne s'occupe que de document légaux et organisationnelle ne bénéficient pas de ces droits car inutiles dans leurs cas.

3.2.3 Stratégie de déploiement des GPO

Afin de déployer les GPO de durcissement, il a été décidé de suivre une approche progressive, tout d'abord, l'ensemble des GPO recommandées ont été réparties dans un classeur excel en fonction de :

- leur nom
- leur description
- le numéro de la recommandation CIS correspondante
- leur impact potentiel sur les utilisateurs et les systèmes
- leur criticité, niveau de sécurité (faible, moyenne, élevée)
- leur pertinence par rapport aux besoins et au contexte de l'entreprise
- leur catégorie (gestion des comptes, sécurité réseau, protection des données, etc.)
- leur statut (À tester, Déployée, Exclue)

Cette classification a permis après une revue par l'ensemble de la DSI (Administrateurs Systèmes et RSSI) de prioriser les GPO les plus importantes avant de les déployer.

Le déploiement a lui été réparties en plusieurs itérations successives espacées dans le temps de plusieurs jours entre chaque, le but était de comprendre au plus vite si une GPO ne fonctionnait pas par rapport à un cas d'utilisation non prévu lors de l'évaluation préliminaire.

Une convention de nommage fut également établie afin de faciliter la gestion et la maintenances des GPO, par exemple, la stratégie *IT1* - Paramétrage des stratégies d'audits* est répartie selon les champs suivants :

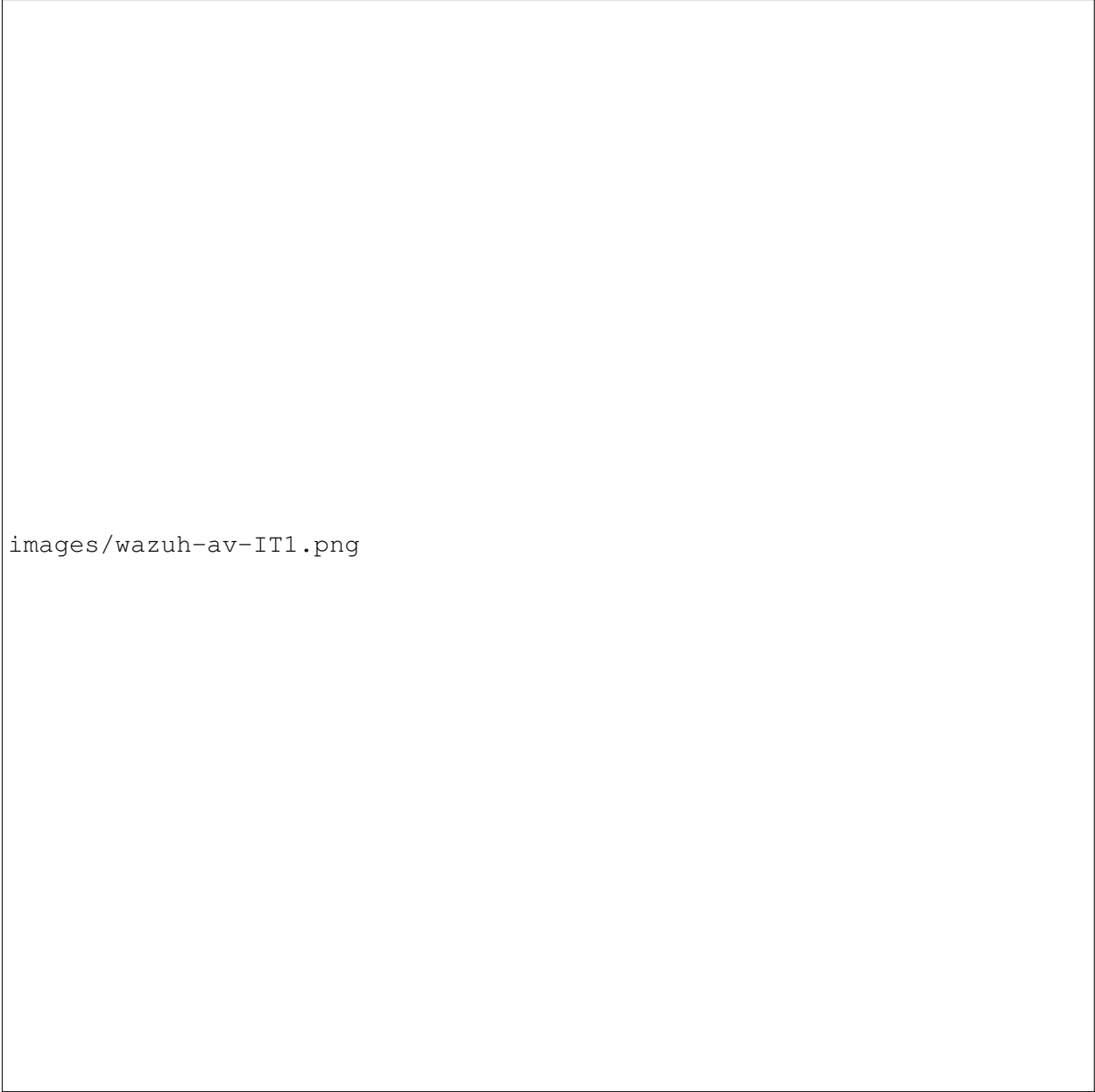
Champ	Description
IT1	Numéro de l'itération durant laquelle la GPO a été créée ou déployée.
*	Indique que plusieurs GPO participent à une même fonctionnalité et sont regroupées logiquement.
Paramétrage des stratégies d'audit	Description concise de l'objectif ou du contenu de la GPO. Les termes utilisés peuvent être « Paramétrage », « Activation », « Désactivation », etc. selon la nature de la configuration appliquée.

TABLE 3 – Convention de nommage des GPO

3.2.4 Evolution de la conformité

Tous les tests de conformités ont été réalisés à l'aide du module SCA de Wazuh sur le PC HP026 situé dans l'OU "Postes\Administrateurs" qui est un poste de travail utilisé par les administrateurs systèmes de l'entreprise.

À ce moment, les quatres premières itérations viennent d'être effectuées, le processus de choix et de revue étant particulièrement long, il se peut que l'on ne puisse avoisiner les 100% de conformité avant la fin de l'alternance, cependant, l'objectif est d'atteindre au moins 70% de conformité sur ce poste. Ci-dessous se trouve la capture d'écran de Wazuh montrant le niveau de conformité du poste HP026 avant le début du déploiement des GPO :



images/wazuh-av-IT1.png

FIGURE 18 – Conformité du poste HP026 avant la première itération de déploiement des GPO

Le poste présente initialement un taux de conformité de 32 %. Ce résultat met en évidence l'écart entre la configuration par défaut du système et les recommandations du benchmark CIS Level 1.

Afin de visualiser la progression obtenue au fil des itérations, le graphique ci-dessous présente l'évolution du taux de conformité aux standards "CIS Level 1" pour le poste HP026, depuis l'état initial jusqu'à la quatrième itération de déploiement des GPO.

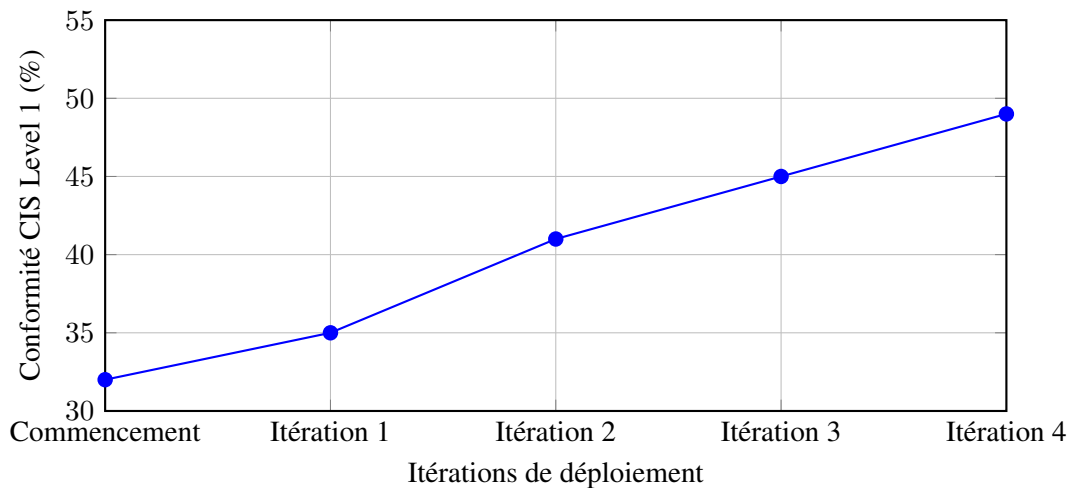


FIGURE 19 – Évolution de la conformité CIS Level 1 du poste HP026 sur 4 itérations

Après l'itération 4, le taux de conformité a atteint 49%, ce qui représente une amélioration significative par rapport à l'état initial de 32%. Il reste cependant une marge de progression afin d'atteindre l'objectif de 70% de conformité, ce qui nécessitera la poursuite du déploiement des GPO et l'ajustement des configurations en fonction des résultats obtenus lors des prochaines itérations.

Ce travail s'inscrit dans un principe de maturité progressive : les GPO sont déployées par étapes, en commençant par les mesures les plus simples et les moins risquées, puis en renforçant progressivement le niveau de protection à mesure que les tests et les retours terrain valident leur stabilité. Cette approche permet d'augmenter le niveau de sécurité sans perturber brutalement les usages.

3.2.5 Exemples concrets de GPO appliquées

Viser un objectif de conformité est intéressant seulement si on donne du sens à cet objectif, il est important de comprendre les différentes attaques ou vulnérabilités que l'on cherche à traiter en appliquant ces GPO, voici quelques exemples concrets de GPO appliquées et des attaques ou vulnérabilités qu'elles permettent de traiter (voir le tableau ??) :

N° CIS	Nom	Objectif technique	Risque traité / Impact
26303	Désactiver l'exécution automatique des médias	Empêcher l'exécution automatique de code depuis supports amovibles (CD, USB, etc.).	Empêche l'exécution de payloads malveillants déposés sur des médias amovibles (auto-run/autoplay). Faible impact pour postes standards, peut gêner certains usages nomades. Déployé en pilote.
26028	Désactiver le cache des ouvertures de session précédentes	Ne pas stocker localement les informations des sessions précédentes (cache d'identifiants/jetons).	Réduit l'impact en cas de vol ou compromission d'un poste (réutilisation de sessions/cookies). Moyennement contraignant pour utilisateurs nomades; à tester avant déploiement large.
26193	Désactiver le protocole LLMNR	Désactiver LLMNR/mDNS sur les interfaces afin d'empêcher la résolution de noms non sécurisée.	Évite les attaques de type LLMNR/NBT-NS poisoning permettant le détournement de trafic et le vol d'identifiants. Recommandé en environnement d'entreprise; faible impact fonctionnel si DNS interne est bien configuré.

TABLE 4 – Exemples concrets de GPO appliquées et des risques associés

3.2.6 Limitation du module SCA de Wazuh

Bien que pratique, le module SCA de Wazuh n'en reste pas moins limité, voici comment il fonctionne :

1. Pour chaque ordinateur / Serveur, un fichier *.xml* avec des commandes pour tester l'application des GPO est envoyé dessus
2. Ces commandes présentes dans le fichier sont ensuite exécutées par un script sur les machines
3. Le résultat de ce script est ensuite envoyé à Wazuh Manager afin d'être traité et de calculer le taux de conformité.

3.2.6.1 Le problème de conformité

Nous avons constaté après l'application de plusieurs GPO que le taux de conformité n'augmentait pas malgré le fait que les GPO soient appliquées sur les machines, après investigation, il s'est avéré que le module SCA ne prenait pas en compte certaines configurations appliquées par les GPO, ce qui faussait le taux de conformité affiché dans Wazuh.

En ouvrant le fichier *xml* envoyé par Wazuh sur les machines nous avons constaté que quand le module SCA testait l'application d'une GPO, il vérifiait la configuration d'une clé de registre spécifique, cependant, certaines GPO appliquaient des configurations qui n'étaient pas liées à des

clés de registre, pour ces dernières, le module test directement de la conformité d'un paramètre via une commande PowerShell, voici un exemple concret :

```
1 - id: 26145
2 title: "Ensure 'Audit Credential Validation' is set to 'Success and
3 description: "This subcategory reports the results of validation
4 tests on credentials submitted for a user account logon request.
5 rationale: "Auditing these events may be useful when investigating
6 a security incident."
7 remediation: "To establish the recommended configuration via GP,
8 [...] Validation"
9 compliance:
10 - cis: ["17.1.1"]
11 - cis_csc: ["8.5"]
12 condition: all
13 rules:
14 - 'c:auditpol.exe /get /subcategory:"Credential Validation"
    -> r:Success and Failure'
```

FIGURE 20 – Exemple d'un test SCA pour vérifier l'application d'une GPO

L'extrait ci-dessus représente un des tests présent dans le fichier *xml* utilisé pour les tests de conformité Windows 11, il est utilisé pour vérifier que la stratégie d'audit "Audit Credential Validation" servant à créer des journaux d'audit lors de la validation des identifiants est bien configuré pour auditer à la fois les succès et les échecs.

Le champ *rules* définit le test à effectuer selon un format spécifique : la commande à exécuter est précédée du préfixe *c* :, tandis que le résultat attendu est précédé du préfixe *r* :. Le test est validé avec succès lorsque la sortie de la commande correspond exactement au résultat escompté ; dans le cas contraire, le test échoue.

Lors de la deuxième itération, après le déploiement des GPO, nous avons constaté que le taux de conformité n'augmentait pas malgré le fait que les GPO soient appliquées, Curieux, nous avons d'abord vérifié que les ordinateurs récupéraient bien les nouvelles GPO :



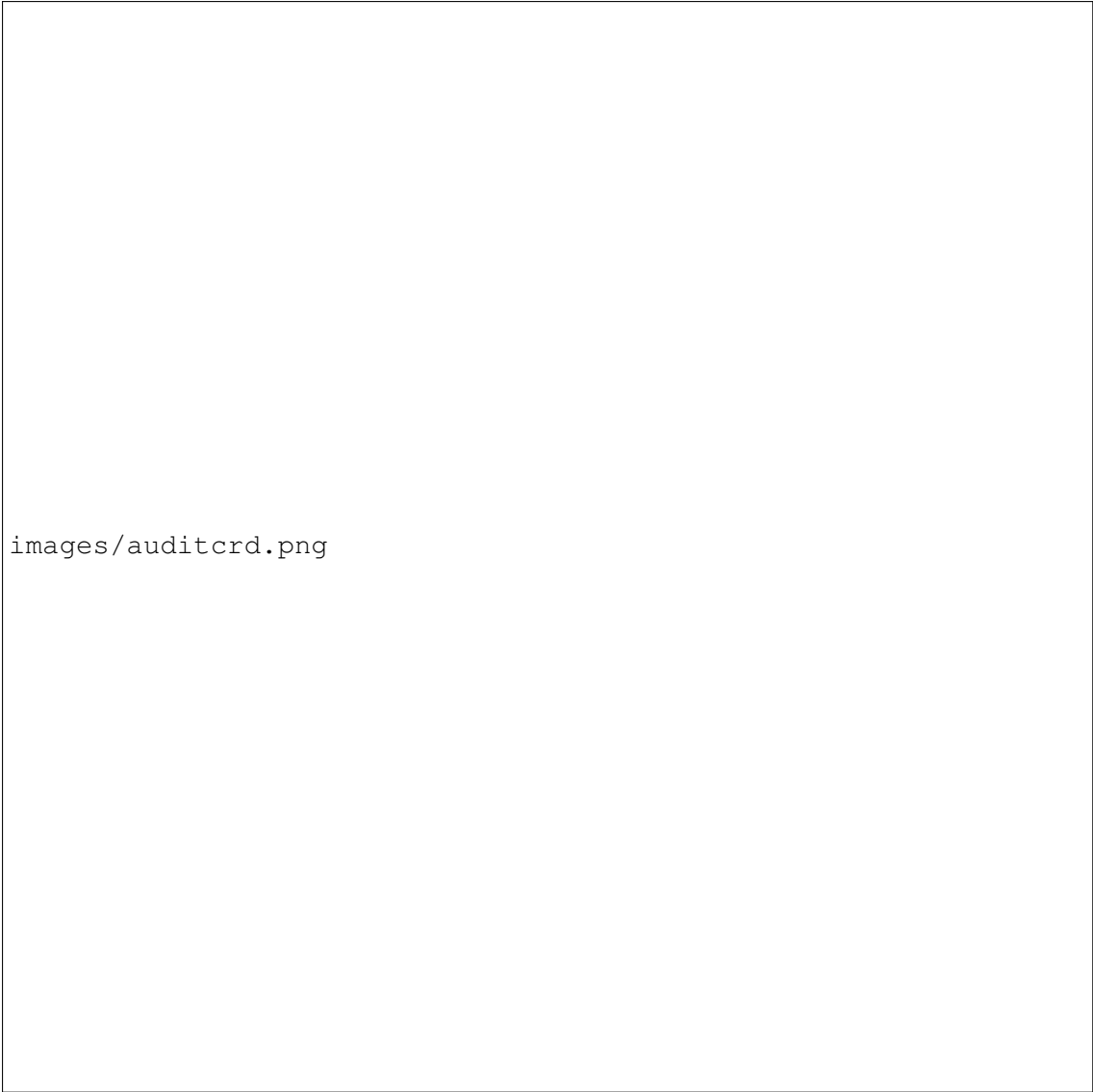
FIGURE 21 – Commande gpupdate pour forcer la récupération des GPO sur le poste HP026

Une fois le rapport généré, nous avons constaté que les GPO étaient bien actives sur le poste :



FIGURE 22 – Rapport d'application des GPO sur le poste HP026

Les GPO attendus apparaissant dans le rapport, nous avons donc décidé de vérifier directement les commandes utilisées par le module SCA pour tester la conformité des GPO :



images/auditcrd.png

FIGURE 23 – Rapport d'application des GPO sur le poste HP026

Cette image affiche la commande `auditpol` utilisée par le module SCA pour vérifier l'application de la GPO "Credential Validation". La commande recherche l'activation du sous-catégorie d'audit correspondante et compare le résultat retourné avec la valeur attendue.

L'exécution de cette commande a révélé plusieurs difonctionnements :

- Le nom de la GPO à vérifier n'était pas correctement écrit, il fallait soit appeler la GPO par son GUID soit par son nom exact dans la langue du système d'exploitation, dans notre cas, le nom de la GPO était "Validation des informations d'identification" au lieu de "Credential Validation"
- Le retour de la commande n'était pas correctement traité, le module SCA attendait le retour "Success and Failure" alors que la commande retournait "Succès et échec" à cause de la langue du système d'exploitation.

3.2.6.2 Solution

Afin de remédier aux problèmes d'incohérence entre le nom de la GPO "Credential Validation" (nom anglais utilisé dans le test) et "Validation des informations d'identification" (nom français sur le système), ainsi que du retour de la commande attendu "Success and Failure" versus "Succès et échec" (en français), il a été décidé de modifier les commandes utilisées par le module afin d'inclure le GUID à la place du nom anglais ainsi que les résultats attendus en utilisant le résultat en français pour ce dernier. Cette modification a été réalisée sur l'ensemble du fichier lorsqu'une commande était utilisée pour vérifier l'application d'une GPO.

L'utilisation des accents dans la langue française a elle posé un autre souci, en effet l'agent Wazuh exécutent les commandes via PowerShell en tant qu'agisseur système, ce qui limite le support UTF-8 natif. Pour contourner ce problème, nous avons encapsulé la commande `auditpol` dans une commande PowerShell avec l'encoding UTF-8, permettant ainsi d'utiliser directement les caractères accentués comme "Succès et échec". La commande suivante a été implémentée :



FIGURE 24 – Commande PowerShell modifiée pour supporter les accents

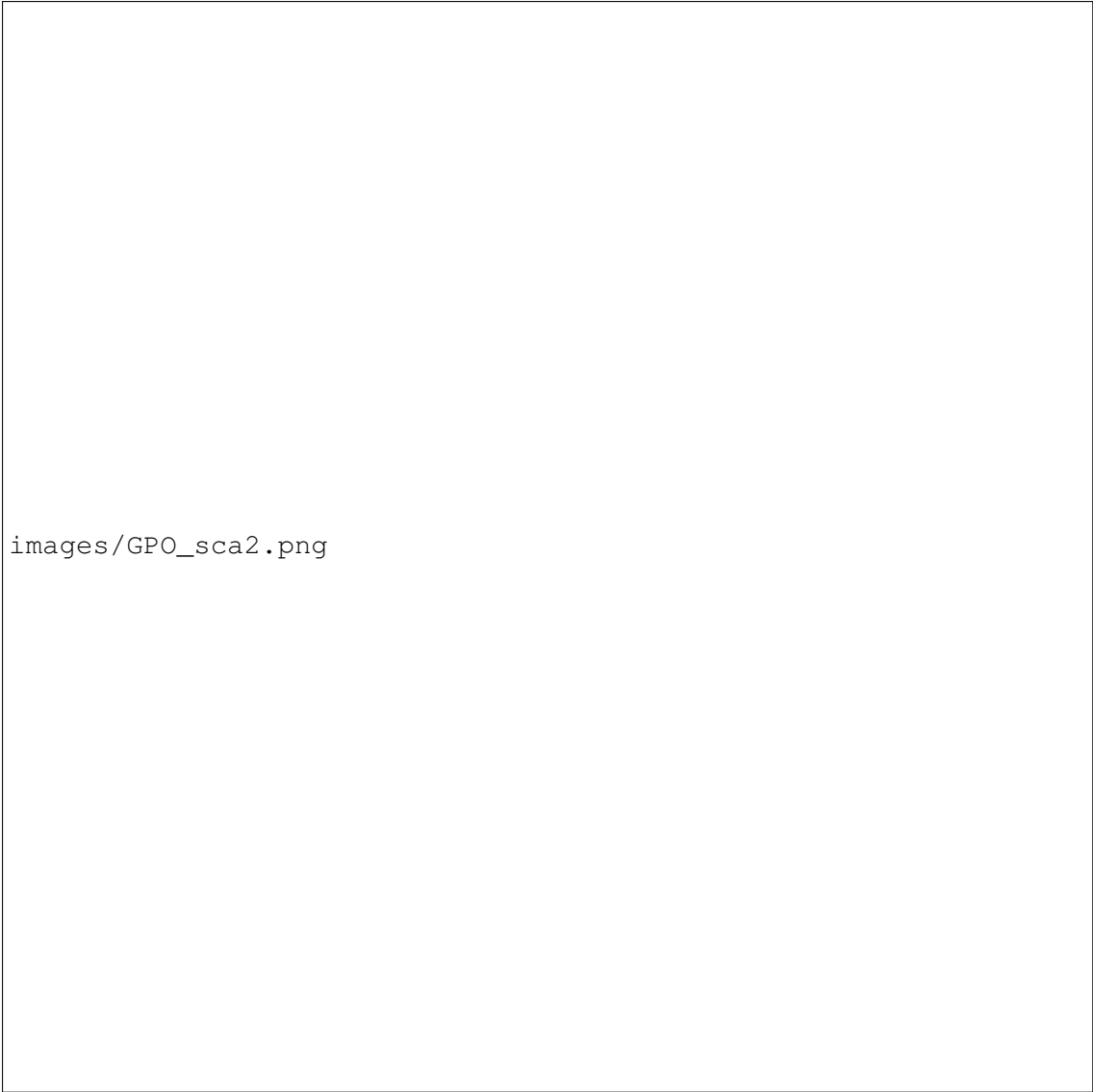
Une fois ce problème réglé, nous avons besoin de déployer le fichier SCA modifié sur l'en-

semble des postes afin de recalculer le taux de conformité. Plusieurs tests ont montré que remplacer le fichier sur le serveur Wazuh Manager (/var/ossec/ruleset/sca ou /var/ossec/test/sca) et supprimer les fichiers locaux ne suffisait pas : les agents ne récupèrent pas automatiquement la nouvelle version.

Nous avons donc choisi de déployer le fichier via une stratégie de groupe (GPO) en utilisant la fonctionnalité "Préférences > Paramètres Windows > Fichiers" pour copier ou remplacer le fichier directement dans le répertoire de l'agent sur chaque poste. Les étapes principales étaient :

- Placer la source du fichier modifié dans un partage réseau accessible par les postes (nous utiliserons ici le partage SYSVOL, un partage de fichier hébergé sur les AD permettant de déployer des GPO, fichiers, scripts etc.).
- Créer une GPO liée à l'unité d'organisation contenant les postes cibles.
- Dans la GPO, aller à : Configuration ordinateur > Préférences > Paramètres Windows > Fichiers ; ajouter une action "Remplacer" avec le chemin source (share) et le chemin de destination local sur les postes (C ://Program Files (x86)/ossec-agent/ruleset/sca).
- Configurer les options (suppressions d'erreurs, attributs, etc.) puis filtrer l'application si nécessaire (par type de machine, groupe de sécurité, etc.).
- Forcer la mise à jour sur quelques machines (gpupdate /force) pour valider le déploiement, puis laisser la GPO se propager.

La figure ci-dessous illustre la configuration de la préférence Fichiers dans la GPO (action "Remplacer", source sur SYSVOL et destination locale) ; la capture du dossier SYSVOL montre l'emplacement où nous avons stocké le fichier source pour la GPO.



images/GPO_sca2.png

FIGURE 25 – Préférence Fichiers dans la GPO pointant vers le fichier SCA sur SYSVOL

Après déploiement, nous avons vérifié sur les postes que le fichier SCA avait bien été remplacé et déclenché une exécution manuelle de l'agent Wazuh pour recalculer le taux de conformité. Cette méthode garantit que tous les postes reçoivent la même version du test sans intervention manuelle sur chaque machine.

3.2.7 Conclusion de la mission et critiques

Cette mission a combiné trois axes d'amélioration complémentaires :

1. **Restructuration de l'Active Directory** : La première étape, la refonte du schéma Active Directory, a fourni une base solide pour l'application future des politiques de sécurité. Cette restructuration hiérarchisée autour des Unités d'Organisation et des groupes de sécurité permet une gestion centralisée et efficace des ressources, tout en respectant le principe du moindre privilège.

2. **Déploiement de stratégies de groupe (GPO) :** Le déploiement des GPO a constitué le cœur du travail, nécessitant à la fois une phase de conception approfondie (classification des recommandations CIS, évaluation des impacts, établissement d'une convention de nommage) et une phase d'itération progressive. Cette approche par itérations espacées s'est avérée judicieuse, permettant de détecter et de corriger rapidement les dysfonctionnements potentiels. Les problèmes rencontrés, notamment les incohérences de langage entre les tests SCA anglais et l'environnement francophone Windows 11, ont pu être résolus de manière ciblée grâce au déploiement du fichier SCA modifié via GPO.
3. **Amélioration de la conformité de sécurité :** Via le module SCA de Wazuh, les mesures de conformité ont été progressivement améliorées et évaluées.

Concernant le taux de conformité, bien que l'objectif de 70% n'ait pas été atteint à la fin des quatre premières itérations (le poste HP026 affichant 49% de conformité), la progression régulière observée — passant de 32% à 49% — démontre l'efficacité de l'approche. Cette trajectoire croissante indique que nous ne sommes pas loin de l'objectif fixé, et que la poursuite des déploiements dans les itérations suivantes permettra de continuer cette amélioration. La maturité progressive mise en œuvre garantit une stabilité du système tout en renforçant progressivement le niveau de protection.

Cette mission illustre l'importance d'une approche structurée, méthodique et itérative pour transformer la posture de sécurité d'une infrastructure informatique, en conjonction avec une bonne compréhension des spécificités locales (langues, environnements hétérogènes) qui peuvent impacter l'application automatisée des contrôles de sécurité.

3.2.7.1 Axe d'amélioration possible - BloodHound

BloodHound est un outil utilisé en Blue Team ou en Red Team, il permet d'analyser de la sécurité des réseaux Active Directory en représentant sous la forme de graphes les relations entre les utilisateurs, les groupes, les ordinateurs ainsi que les permissions au sein d'un domaine. En utilisant BloodHound, il est possible d'identifier les chemins d'attaque potentiels, les comptes à privilèges élevés et les vulnérabilités dans la configuration de l'Active Directory.

L'utilisation de BloodHound pourrait être un axe d'amélioration afin de renforcer davantage la sécurité de l'Active Directory en identifiant les chemins d'attaque potentiels et en mettant en place des mesures pour les atténuer. Par exemple, BloodHound pourrait révéler des comptes avec des permissions excessives ou des relations d'accès non sécurisées, permettant ainsi de les corriger avant qu'elles ne soient exploitées par des attaquants.

BloodHound pourrait par exemple montrer qu'un utilisateur du groupe `Administration` dispose d'un droit `GenericAll` sur un compte de service, et que ce compte soit membre d'un groupe administrateur du domaine. Ce chemin indiquerait qu'un attaquant qui compromet un compte Helpdesk puisse, en quelques étapes, obtenir des privilèges élevés. L'action corrective consisterait à retirer ce droit excessif et à revoir les délégations sur les comptes de service.

4 Impact environnemental et sociétal

4.1 Impact de mes déplacements au long de mon alternance

4.1.1 Déplacements quotidiens

Dans le cadre de mon alternance, j'effectuais un trajet domicile-travail aller-retour chaque jour ouvré. Les émissions de CO₂ ont été estimées à l'aide du calculateur de l'ADEME.

Le trajet quotidien se décompose comme suit :

- **Tramway** : 1,5 km, soit 0,03 g CO₂e/km ;
- **TER Grenoble – Moirans** : 19 km, soit 0,17 g CO₂e/km ;
- **Marche à pied jusqu'au bureau** : 1,1 km, impact négligeable.

L'ensemble du trajet représente environ 3,68 g de CO₂e par déplacement, soit 7,36 g de CO₂e par journée de travail.

Sur une période estimée à 30 semaines d'alternance à raison de 5 jours par semaine, les déplacements domicile-travail représentent environ 1,1 kg de CO₂e émis.

4.1.2 Déplacements ponctuels

Au cours de mon alternance, j'ai été amené à effectuer plusieurs déplacements professionnels, notamment vers le site de Nerys à Gardanne (Bouches-du-Rhône).

Ce trajet a été réalisé en covoiturage à trois personnes à bord d'un véhicule hybride de type SUV. La distance parcourue était d'environ 294 km pour un aller simple, soit 588 km aller-retour.

D'après les estimations réalisées à l'aide du calculateur de l'ADEME, ce déplacement représente environ 11,9 kg de CO₂e pour l'aller-retour.

Bien que cette valeur soit significativement supérieure aux émissions générées par mes trajets quotidiens, ce type de déplacement est resté exceptionnel durant la période d'alternance.

4.2 Actions écologiques et sociales des actions menées par l'entreprise

NERYS GROUP a intégré dans son Système de Management de la Qualité un volet management environnemental (§ 1.6 du MAQ-07-07-033). En fonction des besoins spécifiques de nos clients, cette partie management environnemental peut être complétée par un chapitre dédié dans le Plan de Management Qualité du projet concerné, telles que la gestion d'éliminations de déchets ou la gestion des aspects de pollutions. Consciente de son rôle dans la préservation de l'environnement, NERYS GROUP veille à ce que l'ensemble de ses activités n'impacte pas négativement ses parties intéressées ni son écosystème. Cette vigilance environnementale est une composante essentielle de notre responsabilité sociétale.

4.3 Impacts sociétaux des projets réalisés

[à remplir]

5 Bilan personnel

Cette année d'alternance a été l'occasion de me confronter concrètement aux enjeux de sécurité d'une infrastructure d'entreprise, loin des environnements contrôlés de la formation. La mise en place de Wazuh et le durcissement progressif du système d'information m'ont appris qu'une bonne posture de sécurité ne repose pas uniquement sur des outils, mais sur une démarche cohérente et qualitative qui intègre les contraintes techniques, organisationnelles et humaines comme en témoignent les problèmes d'encodage UTF-8 ou les limites du module SCA, qui ont nécessité des solutions bien plus pragmatiques que prévu.

Au-delà de ces deux missions principales, d'autres projets ont complété cette expérience et élargi ma vision du métier : la migration de l'Active Directory, l'homologation d'un SI classé "Diffusion Restreinte", la documentation du PSSI, la mise en place de Veeam ou encore l'installation de Suricata et Evebox. Ces missions, aux dimensions à la fois techniques et réglementaires, m'ont confronté à la réalité d'un gouvernant SSI dont le rôle dépasse largement la simple administration système.

Cette expérience a confirmé mon intérêt pour la cybersécurité et m'a donné envie d'explorer des perspectives complémentaires, notamment du côté offensif, pour mieux comprendre les menaces que l'on cherche à contrer.

Références bibliographiques

Références

- [1] Center for Internet Security (CIS), [CIS Benchmarks](#), consulté en 2025.
- [2] Microsoft, [Active Directory Documentation](#), consulté en 2025.
- [3] Wazuh, [Wazuh Documentation](#), consulté en 2026.
- [4] Microsoft. (2024). [Security baselines for Windows](#), consulté en 2026.
- [5] Microsoft. (2024). [Windows Server security documentation](#), consulté en 2026.
- [6] Microsoft. (2024). [Active Directory Domain Services overview](#), consulté en 2026.
- [7] Microsoft. (2024). [Best practices for securing Active Directory](#), consulté en 2026.
- [8] Microsoft. (2024). [Group Policy documentation](#), consulté en 2026.
- [9] Wazuh. (2024). [Ruleset documentation](#), consulté en 2026.
- [10] Wazuh. (2024). [Active response documentation](#), consulté en 2026.
- [11] Wazuh. (2024). [Wazuh agent documentation](#), consulté en 2025.
- [12] ANSSI. (2024). *Guide d'hygiène informatique*, consulté en 2026.
- [13] ANSSI. (2024). *Administration sécurisée des systèmes d'exploitation*, consulté en 2026.
- [14] ISO/IEC. (2022). *ISO/IEC 27002 :2022 — Information security, cybersecurity and privacy protection — Information security controls*, consulté en 2026.
- [15] MITRE. (2024). [ATT&CK for enterprise](#), consulté en 2026.
- [16] Cybersecurity and Infrastructure Security Agency. (2024). [Known exploited vulnerabilities catalog](#), consulté en 2026.

Résumé court

Ce rapport présente l'accompagnement en alternance réalisé chez Mesulog, portant sur la conception et le déploiement d'une solution de supervision de sécurité. Il décrit les actions menées (installation d'outils, centralisation des logs, mise en place d'alertes) et les bénéfices obtenus pour la détection et la réponse aux incidents.

Keywords : sécurité, réseau, supervision

Abstract

This report presents a third-year work-study internship carried out within Mesulog in the field of information systems security. The internship focused on the design and deployment of a security supervision solution for the company's IT infrastructure, with the aim of improving visibility, monitoring, and protection of systems and network activity. The report outlines the main tasks completed during the internship, including the installation and configuration of supervision tools, the implementation of alerts and log collection, and the analysis of security events. It also highlights the operational issues encountered and the solutions adopted to ensure reliable monitoring and faster incident response. Overall, this internship provided practical experience in cybersecurity, system administration, and security operations while contributing to the strengthening of the company's security posture.

Keywords : security, network, supervision

Annexes

```
1 # =====
2 # Installation Wazuh mononoeud sur RHEL 10 (step-by-step)
3 # Hote: wazuh@mesulog.local
4 # IP: 192.168.100.113
5 # Doc de reference:
6 # https://documentation.wazuh.com/current/installation-guide/index.html
7 # =====
8
9 # 0) Preparation systeme
10 sudo dnf update -y
11 sudo dnf install -y curl tar coreutils sed grep
12
13
14 # 1 Recuperer l'assistant d'installation Wazuh
15 curl -sO https://packages.wazuh.com/4.8/wazuh-install.sh
16 curl -sO https://packages.wazuh.com/4.8/config.yml
17
18 # Donner les droits d'execution
19 chmod +x wazuh-install.sh
20
21 # 2 Adapter le fichier config.yml pour un mononoeud
22 # (un seul noeud indexer, un serveur, un dashboard)
23 cat > config.yml << 'EOF'
24 nodes:
25   indexer:
26     - name: node-1
27       ip: 192.168.100.113
28
29   server:
30     - name: wazuh-1
31       ip: 192.168.100.113
32
33   dashboard:
34     - name: dashboard
35       ip: 192.168.100.113
36 EOF
37
38
39 # 3 Generer les certificats et fichiers de configuration
40 sudo bash wazuh-install.sh --generate-config-files
41
42 # 4 Installer Wazuh indexer
43 sudo bash wazuh-install.sh --wazuh-indexer node-1
```

FIGURE 26 – Installation de Wazuh sur un serveur RHEL 10 1/2

```

1
2 # 5 Initialiser/demarrer le cluster indexer
3 sudo bash wazuh-install.sh --start-cluster
4
5
6 # 6 Installer Wazuh server
7 sudo bash wazuh-install.sh --wazuh-server wazuh-1
8
9
10 # 7 Installer Wazuh dashboard
11 sudo bash wazuh-install.sh --wazuh-dashboard dashboard
12
13
14 # 8 Verifier l'etat des services
15 sudo systemctl status wazuh-indexer --no-pager
16 sudo systemctl status wazuh-manager --no-pager
17 sudo systemctl status wazuh-dashboard --no-pager
18
19
20 # 9 Ouvrir les ports necessaires (firewalld)
21 # Dashboard HTTPS
22 sudo firewall-cmd --permanent --add-port=443/tcp
23 # Wazuh API
24 sudo firewall-cmd --permanent --add-port=55000/tcp
25 # Agents -> manager
26 sudo firewall-cmd --permanent --add-port=1514/tcp
27 sudo firewall-cmd --permanent --add-port=1515/tcp
28 sudo firewall-cmd --reload
29
30
31 # 10 Recuperer le mot de passe admin genere par l'assistant
32 sudo cat wazuh-passwords.txt
33
34
35 # 11 Acces interface web
36 # URL: https://wazuh.mesulog.local
37 # User: admin
38 # Pass: valeur recuperee dans wazuh-passwords.txt

```

FIGURE 27 – Installation de Wazuh sur un serveur RHEL 10 2/2